Resenha: Model Context Protocol (MCP): Landscape, Security Threats, and Future Research Directions (Hou et al.)

Uma análise do MCP como padrão emergente para integrar modelos de IA a ferramentas externas com foco em arquitetura, segurança e governança.

Referência

HOU, Xinyi; ZHAO, Yanjie; WANG, Shenao; WANG, Haoyu. **Model Context Protocol (MCP): Landscape, Security Threats, and Future Research Directions**. *ACM Transactions on Software Engineering and Methodology*, v. 35, n. 10, p. 1-37, 2026. DOI: 10.1145/3796519. Publicação online: 16 set. 2026.

Fonte 1 | Fonte 2. Referências conferidas em 10 out. 2026.

A versão de acesso aberto consultada é o preprint arXiv v3, de 7 out. 2025. A referência de periódico corresponde ao registro publicado em 2026; as edições são identificadas separadamente.

1. Introdução

O artigo discute o Model Context Protocol (MCP) como uma proposta de padronização para a comunicação entre modelos de IA e ferramentas externas, buscando reduzir a fragmentação causada por integrações específicas, plugins isolados e adaptações manuais. Os autores defendem que o MCP não é apenas uma evolução do function calling, mas uma mudança de paradigma: em vez de cada aplicação acoplar suas próprias integrações, passa-se a ter um protocolo comum, com descoberta dinâmica de capacidades, comunicação bidirecional e maior potencial de interoperabilidade. A tese central do texto é que o MCP já desponta como infraestrutura importante para aplicações de IA orientadas a ferramentas, mas sua adoção segura depende de compreender melhor sua arquitetura, seu ciclo de vida e suas vulnerabilidades.

2. Síntese das ideias principais

O artigo organiza o tema em quatro frentes principais: primeiro, mostra por que abordagens anteriores de integração de ferramentas são limitadas; depois, descreve a arquitetura do MCP e o ciclo de vida de um servidor MCP; em seguida, mapeia o estado atual do ecossistema e seus casos de uso; por fim, apresenta uma taxonomia de ameaças e recomendações práticas para fortalecer a segurança em todas as fases do ciclo de vida.

2.1 MCP como resposta à fragmentação das integrações

Os autores mostram que, antes do MCP, aplicações de IA dependiam de integrações manuais, plugins específicos de plataforma e frameworks de agentes com acoplamentos próprios. Isso gerava retrabalho, manutenção difícil e pouca portabilidade. O MCP surge como resposta a esse cenário ao oferecer um protocolo padronizado para descoberta, descrição e invocação de ferramentas, recursos e prompts. Na prática, isso reduz o custo de integração e permite que diferentes clientes e servidores interoperem sem que cada combinação precise ser construída do zero.

2.2 Arquitetura e ciclo de vida do servidor MCP

Um dos pontos mais relevantes do artigo é a formalização do ciclo de vida de um servidor MCP em quatro fases: criação, implantação, operação e manutenção. Essa divisão ajuda a enxergar o MCP como um sistema completo, e não apenas como uma interface de chamada de ferramentas. Além disso, o texto detalha os papéis de host, client e server, bem como as capacidades centrais do servidor: tools, resources e prompts. Essa modelagem é útil porque organiza tanto a implementação técnica quanto a análise de risco, mostrando onde cada decisão de projeto impacta confiabilidade, governança e segurança.

2.3 Segurança como parte estrutural do ecossistema

O artigo dedica grande atenção à segurança e propõe uma taxonomia com quatro grupos de ameaças: desenvolvedores maliciosos, atacantes externos, usuários maliciosos e falhas de segurança. Entre os exemplos discutidos estão typosquatting, tool poisoning, installer spoofing, indirect prompt injection, credential theft, sandbox escape, tool chaining abuse e unauthorized access. O valor dessa seção está em mostrar que o risco no MCP não se limita ao modelo de IA: ele se distribui ao longo de metadados, instaladores, sessões, configuração, atualizações e integração com serviços externos. Assim, o protocolo amplia capacidades, mas também amplia a superfície de ataque.

2.4 Limites e maturidade ainda desigual do MCP

Embora o artigo reconheça o crescimento do MCP, ele também mostra que o ecossistema ainda é imaturo e heterogêneo. Existem diretórios comunitários com milhares de servidores, mas a qualidade é desigual, a verificação de identidade é limitada e a governança ainda é fraca. Além disso, grandes plataformas podem adotar o MCP de forma parcial, expondo apenas funções de baixo risco e mantendo partes estratégicas sob forte controle. Isso revela um ponto importante: a promessa de interoperabilidade não depende apenas da qualidade técnica do protocolo, mas também de incentivos econômicos, políticas de acesso e mecanismos institucionais de confiança.

2.5 Implicações práticas, trade-offs e recomendações

A principal implicação prática do texto é que adotar MCP exige equilibrar extensibilidade e controle. O protocolo pode simplificar integrações, acelerar fluxos multiagente e ampliar o reuso de ferramentas, mas isso só se sustenta com medidas como assinatura criptográfica, versionamento confiável, isolamento por sandbox, validação de metadados, auditoria de acesso, monitoramento de logs e gestão segura de credenciais. Em outras palavras, o ganho de flexibilidade traz custos de governança. O artigo é convincente ao mostrar que interoperabilidade sem mecanismos robustos de confiança pode transformar conveniência em vulnerabilidade sistêmica.

3. Aplicação imaginada dos conceitos

Em um projeto real, os conceitos do artigo poderiam ser aplicados no desenvolvimento de uma plataforma interna de assistentes de IA para engenharia de software. Nesse cenário, um host poderia conectar-se a servidores MCP responsáveis por integração com GitHub, banco de dados, documentação técnica, monitoramento e mensageria. A vantagem imediata seria padronizar o acesso a essas ferramentas, reduzindo adaptações específicas e facilitando a evolução do ecossistema. Um mesmo assistente poderia, por exemplo, consultar issues, recuperar métricas de produção e abrir uma tarefa de correção sem depender de integrações isoladas para cada serviço.

Ao mesmo tempo, o artigo mostra que esse tipo de projeto precisaria nascer com controles claros. Cada servidor deveria ser empacotado com assinatura verificável, permissões mínimas, segregação de ambientes e auditoria contínua. Um servidor de leitura de repositório não deveria ter permissão para escrever código; um servidor de banco de dados deveria operar com conta restrita e, quando possível, apenas leitura; e prompts ou descrições de ferramentas precisariam passar por validação para evitar manipulação de preferência ou envenenamento. Assim, a principal aplicação prática da leitura não é apenas “usar MCP”, mas usar MCP com arquitetura defensiva desde o início.

4. Conclusão

O principal aprendizado do artigo é que o MCP tem potencial para se tornar uma camada padronizada de integração entre modelos e ferramentas, mas sua consolidação depende de maturidade técnica e institucional. O texto é forte ao combinar arquitetura, ecossistema e segurança em uma visão única, oferecendo uma leitura útil tanto para pesquisadores quanto para quem projeta sistemas com agentes de IA. Como limitação, por ser um panorama amplo de um ecossistema ainda em rápida evolução, parte das conclusões pode envelhecer rapidamente e exigir revisão contínua. Ainda assim, a contribuição central permanece sólida: protocolos de interoperabilidade para IA só serão realmente úteis em larga escala se forem acompanhados por mecanismos sérios de confiança, isolamento e governança.